FIREBRAND
LYCEUM EDUCATION GROUP

Module 4: Software Design
Session 5: Secure by Design and Reusable Patterns

Software Developer Level 4



What you will be able to do

By the end of this session you will be able to:

1. Analyse a given design against security and maintainability requirements to identify weaknesses.
2. Evaluate design patterns and recommend those that solve recurring problems in the design.
3. Justify a design change in an architecture decision record.

FIREBRAND
LYCEUM EDUCATION GROUP

Correct, and still unsafe

PREPARE QUESTION

Who should be able to see a tenant's health details, and who should not?

Type your answer in the chat, but wait for 'go'. A design can do everything it was asked and still put a tenant at risk.

FIREBRAND
LYCEUM EDUCATION GROUP

Secure by design

Principles, the law and Kestrel Moor's own rules: what to check, and when each one applies.

FIREBRAND
LYCEUM EDUCATION GROUP

Seven principles to hold a design against

Each principle has a Kestrel Moor requirement behind it in Case Brief Part 5.

1. **Least privilege**
   Each role gets only the access its work needs.
2. **Data minimisation**
   Collect, show and send only the fields a purpose needs.
3. **Validate on the server**
   Browser checks help users; only server checks protect.
4. **Secure defaults**
   Safe out of the box: a new account starts with the least.
5. **Fail securely, never silently**
   When a step fails, stay safe and tell someone who can act.
6. **Defence in depth**
   Layer controls so one failure is not a breach.
7. **Keep links and errors clean**
   No secrets or personal data in URLs or error text.

FIREBRAND
LYCEUM EDUCATION GROUP

Health details are already on the move

24

of the 150 sample requests carry a vulnerability note

For example: 'COPD, uses oxygen at home', 'Mental health condition, prefers a named contact', 'Uses a wheelchair'.

Most describe health or disability: special category data under UK GDPR Article 9.

Today the job sheet copies the whole record, note included, to whoever does the job.

FIREBRAND
LYCEUM EDUCATION GROUP

The law behind the rules

Duty	What it says	What it means for your design
UK GDPR Article 5(1)(c): data minimisation	Personal data must be adequate, relevant and limited to what is necessary	Each screen, message and export carries only the fields its purpose needs
UK GDPR Article 9: special category data	Processing health data is prohibited unless an Article 9 condition applies	Most vulnerability notes are health or disability data: fewer people, more care
UK GDPR Article 25: by design and by default	Build protection in from the start; by default, data is not open to an indefinite number of people	Privacy is a design input, not a test at the end
Awaab's Law (from 27 October 2025)	Emergency hazards investigated and made safe within 24 hours; significant damp and mould hazards investigated within 10 working days	Treat these timescales as safety requirements the design must protect

FIREBRAND
LYCEUM EDUCATION GROUP

Acting with integrity

“An operative needs to know ‘tenant uses a wheelchair, allow time at the door’; they do not need a diagnosis.”

Tom Reid, Data Protection Officer

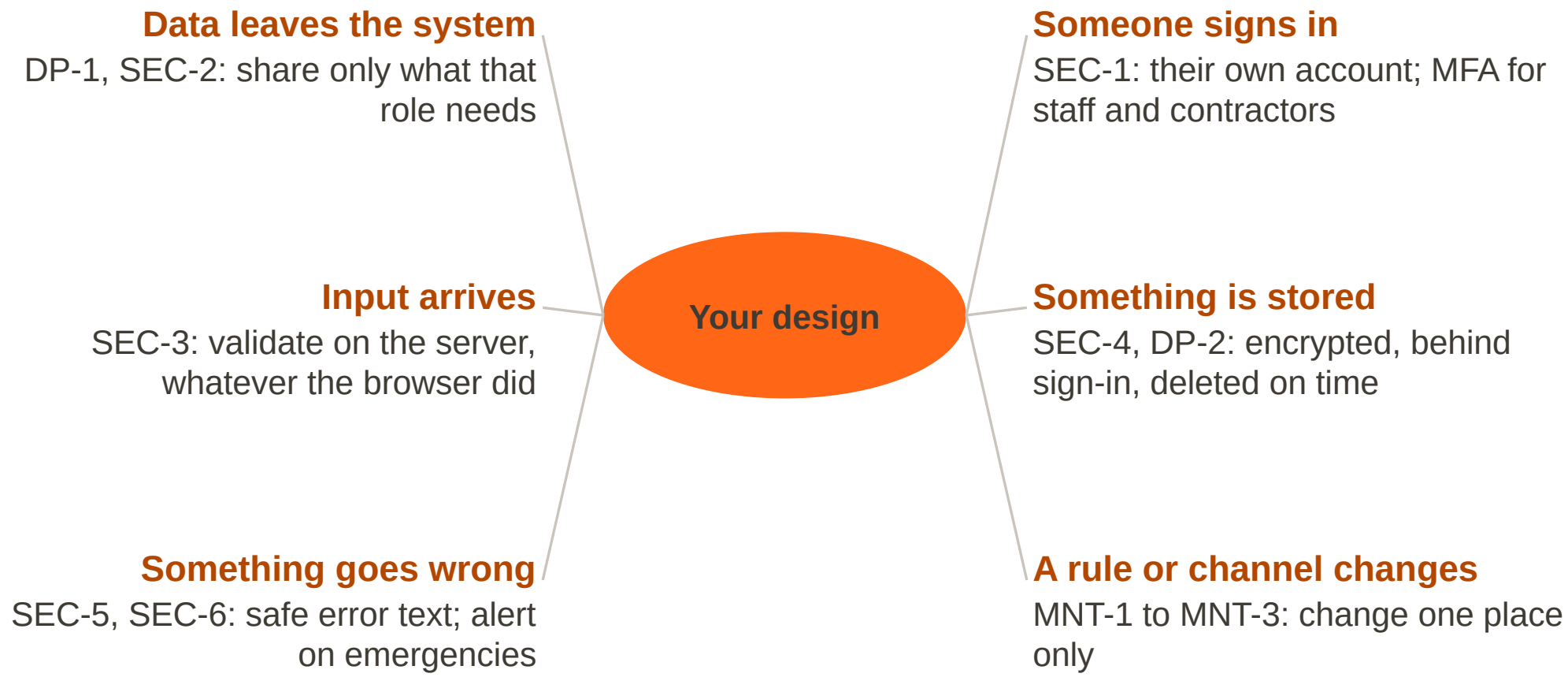
Integrity means meeting your legal, regulatory and ethical duties when nobody is checking.

If a design asks you to share more than the job needs, say so, and ask the Data Protection Officer before you build.



FIREBRAND
LYCEUM EDUCATION GROUP

Which policy, when?



FIREBRAND
LYCEUM EDUCATION GROUP

Reading a given design

How to review a design you did not write, then a review of the agency's draft.

FIREBRAND
LYCEUM EDUCATION GROUP

Reviewing a design you did not write



The agency says its draft meets the brief. Your job is to check, not to trust.

At work this is common: a supplier's design, a senior colleague's, or one inherited from a team that has moved on.

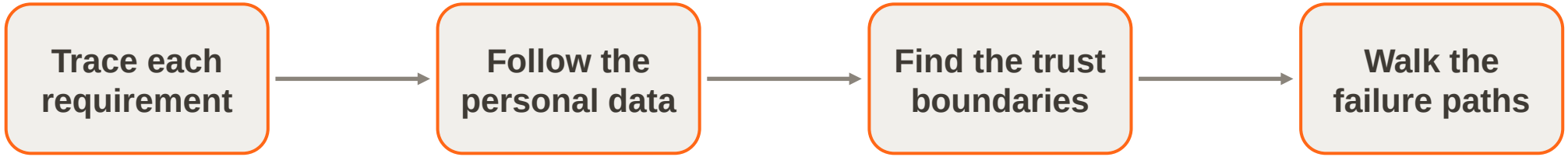
Review it against the client's written requirements, not your own taste.

Every finding names the requirement it breaks, so the author can act on it.

FIREBRAND
LYCEUM EDUCATION GROUP

Four passes through a design

Read the design four times, with one question each time.



Where does the design meet each one? No home means a gap.

Who can see each field, and does each one need it?

What is checked where data crosses in or out?

What happens when a step fails, and who finds out?

Log each weakness: what it is, the requirement it breaks, the risk, and a severity (high, medium or low).

Worked example: a different system

Two weaknesses in a rent reminder design, logged the way you will log yours.

RENT REMINDERS: DRAFT (EXCERPT)

A nightly job finds rent accounts in arrears.

(1) It texts the tenant: 'Ms R. Patel, account 4471-22 is in arrears. Pay now at rent.example/pay'

The tenant pays on the payment provider's own page.

(2) The provider then calls /rent/paid?account=4471-22 and the service marks the account as paid.

1. Personal data: name, account and debt on a phone's lock screen. Breaks data minimisation. Risk: debt disclosed to anyone in the household. Medium.

2. Trust boundary: the service believes any caller. Breaks server-side validation. Risk: anyone can clear their own arrears. High.

FIREBRAND LYCEUM EDUCATION GROUP

Activity 1: Review the agency's design

Pairs, breakout rooms

Find where the agency's draft breaks Kestrel Moor's requirements, before anyone builds it.

1. On your own, 2 minutes: read both diagrams in Supporting Material Part A and note what worries you.
2. Together, trace each requirement in the Part A checklist through the diagrams.
3. Follow the personal data, cross each trust boundary and walk each failure path.
4. Log five weaknesses: what and where, the requirement it breaks, the risk and its severity.
5. Rank your log and write your top two.

TIME
26 minutes working time

GROUPING
Pairs, breakout rooms

YOU NEED
Supporting Material Part A
Activities: weakness log

OUTPUT AND SUCCESS
A log of five weaknesses, each with a requirement, a risk and a severity, and your top two.

Debrief: Which weakness would hurt a tenant first, and which requirement does it break?

FIREBRAND
LYCEUM EDUCATION GROUP

Break

20 minutes

Keep your weakness log open. After the break: four patterns that fix recurring design problems, then you redesign the agency's classes.

FIREBRAND
LYCEUM EDUCATION GROUP

Reusable patterns

Four proven answers to problems that keep coming back, and when not to use them.

FIREBRAND
LYCEUM EDUCATION GROUP

What a pattern is

RECAP

> **A pattern is a named, reusable solution to a problem that keeps coming back.**

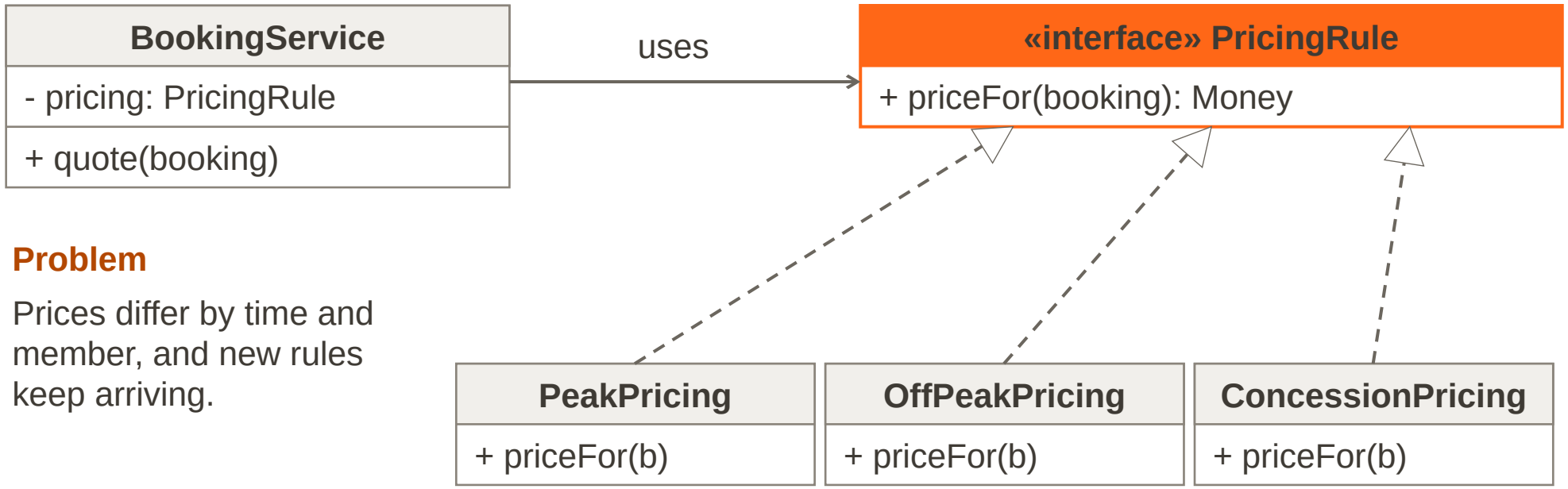
Gamma, Helm, Johnson and Vlissides (1994) catalogued 23 for object-oriented design, borrowing the idea from the architect Christopher Alexander (1977).

A pattern name is shorthand: 'Strategy for the pricing' tells a colleague the whole structure.

No recurring problem, no pattern: a pattern added for its own sake is just more code.

FIREBRAND LYCEUM EDUCATION GROUP

Strategy: swap the rule, keep the caller



Problem

Prices differ by time and member, and new rules keep arriving.

Junior pricing is one new class; BookingService never changes.

Observer: announce it, let others react

COURT BOOKING (PSEUDOCODE)

```
class CourtBooking:
  def cancel(self):
    self.status = 'Cancelled'
(1)
events.publish(BookingCancelled(self.id))

(2) events.subscribe(BookingCancelled,
      waiting_list.offer_place)
    events.subscribe(BookingCancelled,
      refunds.issue)
    events.subscribe(BookingCancelled,
      usage_report.update)
```

1. The booking announces what happened. It does not know who is listening.

2. Each reaction subscribes itself. Adding one needs no change to CourtBooking.

3. Events can carry the ID only; each listener fetches what its role may see.

Factory Method and Repository

Factory Method: controlled creation

Problem: several kinds of object, and creating each needs rules.

Structure: callers ask a factory method; it decides which class to build.

Example: BookingFactory.create(activity) returns a SwimBooking or a GymBooking, each built with its own checks.

Helps: no screen can create a booking that skips the checks.

Repository: one door to the data

Problem: data access scattered across screens, each with its own query.

Structure: a collection-like object that callers ask for domain objects.

Example: MemberRepository.findForInstructor(classId) returns first names and attendance only.

Helps: each role's data comes from one query in one place.

FIREBRAND LYCEUM EDUCATION GROUP

Activity 2: Fix the design with patterns

Pairs, breakout rooms

Redesign the agency's classes so they meet the requirements, using patterns you can justify.

1. Save your own copy of the starter file, open it in draw.io and go to the page Your revised design.
2. Fix the weaknesses that break SEC-2, MNT-1 and SEC-6: add, split or remove classes and links.
3. Use two or more patterns from Part C: note the problem each solves and why you chose it.
4. Label every change with the requirement it meets, for example MNT-2.
5. Before the room closes, the driver posts the .drawio file and a PNG in the breakout chat.

TIME
25 minutes working time

GROUPING
Pairs, breakout rooms

YOU NEED
Starter file (draw.io)
Your weakness log
Supporting Material Part C

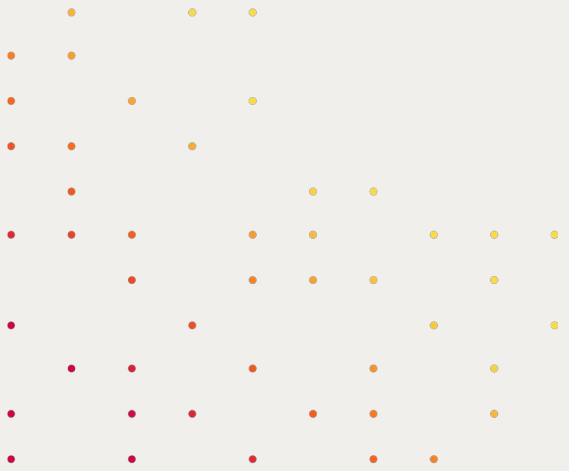
OUTPUT AND SUCCESS
A revised class diagram: three fixes, two or more named patterns, every change labelled.

Debrief: Which pattern did the most work in your design, and what would break without it?

FIREBRAND LYCEUM EDUCATION GROUP

Recording the decision

An architecture decision record tells the next developer why, not only what.



FIREBRAND
LYCEUM EDUCATION GROUP

Why write the decision down

Six months on, a new developer asks why the design works this way.

An ADR answers in one page: the problem, what we decided, what we rejected, and what it costs.

Write it for a future developer, and for the people who live with the decision: advisers, tenants, contractors.

Nygard (2011): one short record per significant decision, numbered, never deleted.



FIREBRAND
LYCEUM EDUCATION GROUP

Worked example: an ADR on a different decision

ADR 7 (RENT SYSTEM, EXCERPT)

(1) Title: Put the rent payment provider behind our own PaymentGateway interface

Status: Accepted

(2) Context: each rent screen calls the provider's API directly; finance may switch provider when the contract ends.

Decision: We will define PaymentGateway and call it from every screen.

(3) Alternatives: keep direct calls (rejected: every screen changes on a switch).

(4) Consequences: one place for retries and logging; one more interface to test.

1. The title states the decision, not the topic.
2. Context gives the forces, in neutral words.
3. Alternatives show the choice was real.
4. Consequences include a cost, not just gains.

FIREBRAND LYCEUM EDUCATION GROUP

Activity 3: Record the decision

On your own

Justify one change from your redesign so a future developer understands why it was made.

1. Pick one change a new developer might question. Title it as the decision; status Proposed.
2. Context: the requirement, what the agency's design did and who is affected (Case Brief Part 2).
3. Decision: full sentences starting 'We will', naming the pattern, if any.
4. Alternatives: two options you rejected, each with its reason.
5. Integrity: the Head of Repairs wants contractors to see full vulnerability notes. What do you do, and which rule applies?

TIME
15 minutes working time

GROUPING
On your own

YOU NEED
Your revised design
Supporting Material Part D
Case Brief Part 2
Activities: ADR table

OUTPUT AND SUCCESS
One ADR, title to alternatives, a new developer could act on, and your integrity reply.

Debrief: Read your Decision and one rejected alternative aloud: would a new developer know why?

FIREBRAND
LYCEUM EDUCATION GROUP

Live check

CHECK

1. Each contractor takes jobs a different way, and more will join. Which pattern fits?

A Observer: each contractor's system subscribes to every new job event
B Strategy: one JobSender interface, one class per contractor's method
C Singleton: one shared sender object holding every contractor's settings
D Repository: a JobRepository that records how each contractor takes work

2. An adviser will email a contractor open jobs with tenant notes. Which rule applies first?

A DP-1: personal data is leaving the system, so send only what the job needs
B SEC-3: the list is input, so the server must validate it before it is sent
C MNT-3: priority rules belong in one place, not in an emailed list
D SEC-5: the email must not reveal system details to the contractor

3. An emergency job is rejected at 23:40; the screen still says 'Job sent'. What is wrong?

A The error message shows system details to the adviser on screen
B The job should have been fetched through a Repository, not the API
C It fails silently: nobody is told, which could delay making the home safe
D Debug logs can hold personal data, so this logging breaks data minimisation

FIREBRAND
LYCEUM EDUCATION GROUP

Skills covered today

KSB and official wording	In plain English	Where we covered it today
Part of K7: patterns; to identify reusable solutions to commonly occurring problems	Using proven patterns to fix recurring design problems	Activities 2 and 3; live check
K8: organisational policies and procedures relating to the tasks being undertaken, and when to follow them. For example the storage and treatment of GDPR sensitive data.	Applying Kestrel Moor's data protection and security rules to a design	Activity 1; live check
Part of S17: interpret ... a given design whist [sic] remaining compliant with security and maintainability requirements	Reading a third party's design and checking it against security and maintainability requirements	Activities 1 to 3
Part of B5: Acts with integrity with respect to ethical, legal and regulatory; ensuring the protection of personal data; security	Protecting tenants' personal data and the system	Activities 1 to 3; live check

FIREBRAND
LYCEUM EDUCATION GROUP

What to take away

1. A design can meet its brief and still break security or data protection rules.
2. Four passes: requirements, personal data, trust boundaries, failure paths.
3. Use a pattern only for a recurring problem, and say which problem it solves.
4. An ADR tells the next developer why, what you rejected and what it costs.

Before Session 6

Do the Consolidate quiz: Secure by Design and Reusable Patterns - Consolidate Quiz (about 10 minutes).

Complete the Session 6 Prepare document: choose your own project (no real personal or customer data) and read the review criteria and role cards.

Optional: the Session 5 stretch deck, six ideas behind today's session.

FIREBRAND
LYCEUM EDUCATION GROUP

Reflective Log

Complete the Session 5 entry in Reflective Log.docx: a summary of your architecture decision record.

Write the decision in one sentence, the requirement it meets, and the cost you accepted.

Then copy the key points into your OneFile timesheet reflection.

Keep it general: no personal or customer data, credentials or confidential material, and no employer data in AI tools your employer has not approved.

FIREBRAND
LYCEUM EDUCATION GROUP

FIREBRAND
LYCEUM EDUCATION GROUP

Contact us

+44 (0)207 907 1120

info@firebrandtraining.co.uk

firebrand.training